

Инфобез_лабораторная_5_Иванченкова Арина

Я прикладываю pdf, потому что иначе картинки не будет видно.

1 часть

результат выполнения команды

```
docker image ls
```

REPOSITORY SIZE	TAG	IMAGE ID	CREATED
vedroru-backend 716MB	latest	95f375962ae4	5 days ago
vedroru-frontend 80.1MB	latest	d416d9d5b522	5 days ago
dpage/pgadmin4 823MB	latest	50700ac17936	4 months ago
nginx 79.8MB	alpine	b3c656d55d7a	6 months ago
vedro-frontend 1.16GB	latest	3d0d95119b1f	6 months ago
vedro-frontend2 79.9MB	latest	d4ff62967f88	6 months ago
vedro-frontend1 79.9MB	latest	f03e69dcc63d	6 months ago
postgres 390MB	15-alpine	64583b3cb4f2	6 months ago
postgres 643MB	latest	1ffc019dae94	6 months ago
mysql 689MB	5.7	4bc6bc963e6d	2 years ago
ket9/otus-devsecops-xss 559MB	latest	5fe11667b03c	4 years ago
ket9/otus-devsecops-owasp-rest 451MB	latest	9da7b7d1e2a8	4 years ago
ket9/otus-devsecops 720MB	latest	a85cce3b4064	10 years ago

```
PS C:\Users\Space Witch> whoami
space\space_witch
PS C:\Users\Space Witch> docker run -it boring_hopper sh
Unable to find image 'boring_hopper:latest' locally
docker: Error response from daemon: pull access denied for boring_hopper, repository does not exist or may require 'docker login'
```

```
Run 'docker run --help' for more information
PS C:\Users\Space Witch> docker run -it ket9/otus-devsecops-xss sh
# whoami
root
# █
```

Видим, что запускаем приложение от лица пользователя root

2 часть

Написание Docker файла

```
1s
=> => naming to docker.io/library/hwimage:latest 0
0s
=> => unpacking to docker.io/library/hwimage:latest 0
3s
PS C:\Users\Space Witch\Desktop\devsec_hw> docker run -it hwimage sh
$ whoami
notroot
$ █
```

DockerFile:

```
FROM ket9/otus-devsecops-xss:latest
EXPOSE 8080

RUN useradd -m -u 1000 notroot
RUN chown -R notroot:notroot /app

USER notroot

CMD ["sh", "-c", "python app.py || python3 app.py || flask run --host=0.0.0.0 --port=8080"]

# Дополнительные настройки безопасности
# Можно добавить проверку на признаки жизни контейнера
# HEALTHCHECK
# WORKDIR – установка рабочей директории
# COPY с указанием владельца – копирует файлы
# и даёт права не root пользователю
# LABEL – метаданные для отслеживания безопасности
```

```
# Флаги
# --read-only - запрет на запись
# в контейнер, разрешено только чтение
# --restart=on-failure - перезапуск контейнера, если он упал
# --cpus="0.5" - чтобы контейнер сильно не нагружал процессор
```

3 часть

Я решила просканировать образ через trivy
вот скриншот с ответом сканера(на него попала часть таблицы. \ Скриншотов всей
таблицы не будет, так как она просто огромная)

```
2026-04-27T19:53:37+03:00 INFO [vuln] Need to update DB
2026-04-27T19:53:37+03:00 INFO [vuln] Downloading vulnerability DB...
2026-04-27T19:53:37+03:00 INFO [vuln] Downloading artifact... repo="mirror.gcr.io/aquasec/trivy-db:2"
91.50 MiB / 91.50 MiB [-----] 100.00% 4.95 MiB p/s 19s
2026-04-27T19:53:58+03:00 INFO [vuln] Artifact successfully downloaded repo="mirror.gcr.io/aquasec/trivy-db:2"
2026-04-27T19:53:58+03:00 INFO [vuln] Vulnerability scanning is enabled
2026-04-27T19:53:58+03:00 INFO [secret] Secret scanning is enabled
2026-04-27T19:53:58+03:00 INFO [secret] If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2026-04-27T19:53:58+03:00 INFO [secret] Please see https://trivy.dev/docs/v0.70/guide/scanner/secret#recommendation for faster secret detection
2026-04-27T19:54:12+03:00 INFO Detected OS family="debian" version="9.6"
2026-04-27T19:54:12+03:00 INFO [debian] Detecting vulnerabilities... os_version="9" pkg_num=169
2026-04-27T19:54:12+03:00 INFO Number of language-specific files num=0
2026-04-27T19:54:12+03:00 WARN Using severities from other vendors for some vulnerabilities. Read https://trivy.dev/docs/v0.70/guide/scanner/vulnerability#severi
ty-selection for details.
2026-04-27T19:54:12+03:00 WARN This OS version is no longer supported by the distribution family="debian" version="9.6"
2026-04-27T19:54:12+03:00 WARN The vulnerability detection may be insufficient because security updates are not provided

Report Summary

+-----+-----+-----+-----+
| Target | Type | Vulnerabilities | Secrets |
+-----+-----+-----+-----+
| hwimage (debian 9.6) | debian | 1169 | - |
+-----+-----+-----+-----+

Legend:
- '-': Not scanned
- '0': Clean (no security findings detected)

hwimage (debian 9.6)
=====
Total: 1169 (UNKNOWN: 12, LOW: 186, MEDIUM: 426, HIGH: 463, CRITICAL: 82)

+-----+-----+-----+-----+-----+-----+-----+
| Library | Vulnerability | Severity | Status | Installed Version | Fixed Version | Title |
+-----+-----+-----+-----+-----+-----+-----+
| apache2 | CVE-2019-10082 | CRITICAL | fixed | 2.4.25-3+deb9u6 | 2.4.25-3+deb9u8 | httpd: read-after-free in h2 con | |
| nection shutdown | | | | | | | https://avd.aquasec.com/nvd/cve- |
| 2019-10082 | | | | | | | |
+-----+-----+-----+-----+-----+-----+-----+
| w via a crafted | CVE-2021-26691 | | | | 2.4.25-3+deb9u10 | httpd: mod_session: Heap overflo | |
| w | | | | | | | SessionHeader value |
| | | | | | | | https://avd.aquasec.com/nvd/cve- |
+-----+-----+-----+-----+-----+-----+-----+
```

```
2026-04-27T20:36:32+03:00desktop\INFOec_h[vuln] Vulnerability scanning is
enabled
2026-04-27T20:36:32+03:00 INFO [secret] Secret scanning is enabled
2026-04-27T20:36:32+03:00 INFO [secret] If your scanning is slow,
please try '--scanners vuln' to disable secret scanning
2026-04-27T20:36:32+03:00 INFO [secret] Please see
https://trivy.dev/docs/v0.70/guide/scanner/secret#recommendation for faster
secret detection
2026-04-27T20:36:32+03:00 INFO Detected OS family="debian"
version="9.6"
2026-04-27T20:36:32+03:00 INFO [debian] Detecting vulnerabilities...
os_version="9" pkg_num=169
2026-04-27T20:36:32+03:00 INFO Number of language-specific files
num=0
```

```
2026-04-27T20:36:32+03:00      WARN      Using severities from other vendors
for some vulnerabilities. Read
https://trivy.dev/docs/v0.70/guide/scanner/vulnerability#severity-selection
for details.
2026-04-27T20:36:32+03:00      WARN      This OS version is no longer supported
by the distribution      family="debian" version="9.6"
2026-04-27T20:36:32+03:00      WARN      The vulnerability detection may be
insufficient because security updates are not provided
```

Report Summary

Target	Type	Vulnerabilities	Secrets
hwimage (debian 9.6)	debian	1169	-

Legend:

- '-': Not scanned
- '0': Clean (no security findings detected)

hwimage (debian 9.6)

=====

Total: 1169 (UNKNOWN: 12, LOW: 186, MEDIUM: 426, HIGH: 463, CRITICAL: 82)

Что мы видим на скриншоте:

Всего у нас 1169 уязвимостей (многовато. Наверное, для \ учебного образа это нормально).

Критических - 82

С высокой степенью опасности - 463

С умеренной степенью опасности - 426

С низкой - 186

Неизвестные уязвимости - 12

Также у нас есть несколько WARNINGS(предупреждений) \

1. Образ основан на очень старой версии операционной \ системы, которая больше не поддерживается.
2. Для этой версии операционной системы обновления \ больше не выходят.(обновления безопасности не выходят соответственно)

Что можно сказать про этот образ...

Был бы он не учебным для практики, а вполне реальным, для выкатки в прод, отдел

информационной безопасности хватил бы Кондратий.

После добавления notroot пользователя при взломе приложения(давайте представим, что других дыр здесь нет) злоумышленнику будет затруднительно получить доступ от лица root пользователя.